

Manual 33 — Implementação controlada de Governança e Divulgação de Cibersegurança da SEC

****Idioma:**** Português do Brasil (pt-BR)

****Linha de base regulatória:**** SEC Release No. 33-11216, Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure, vigente desde 5 de setembro de 2023, com formulários e materiais oficiais da SEC reverificados em 31 de agosto de 2026.

****Limite controlado:**** Esta edição é uma tradução não oficial e guia de implementação. Não fornece aconselhamento jurídico, não determina status do emissor nem materialidade, não autoriza atraso de divulgação, não realiza filing e não certifica compliance.

Regras/formulários vinculantes, orientação SEC, propostas não efetivas, fatos de enforcement e prática do emissor permanecem separados.

Chapter 01 — Propósito, escopo e hierarquia controlada de fontes

Use regras e formulários vigentes da SEC como camada vinculante. Trate guidance, compliance guides, speeches, FAQs, enforcement, petitions e proposals conforme seu status jurídico e data; procedimentos internos nunca devem ser apresentados como regras da SEC.

Chapter 02 — Status do emissor e análise de aplicabilidade

Mantenha avaliação documentada de tipo de registrant, status sob Exchange Act, domestic versus foreign private issuer, formulários aplicáveis, calendário de reporting e responsáveis por disclosure controls. Escale dúvidas a securities counsel qualificado.

Chapter 03 — Definições e governança terminológica

Mantenha glossário controlado para cybersecurity incident, cybersecurity threat, information systems, materiality, board oversight, management role, disclosure controls, Forms 8-K/6-K/10-K/20-F, Regulation S-K Item 106 e Inline XBRL. Preserve o significado SEC quando a terminologia interna divergir.

Chapter 04 — Governança de cibersegurança e supervisão do board

Documente como o board ou committee responsável supervisiona riscos materiais de ameaças cibernéticas, incluindo fluxo de informações, frequência, escalonamento, incidentes significativos, tendências e reporting de management. A evidência deve sustentar divulgação anual sem transformar materiais comuns do board em conclusões jurídicas não suportadas.

Chapter 05 — Papéis e accountability de management

Defina papéis responsáveis por avaliar e gerir riscos materiais de cibersegurança, incluindo CISO/security, legal, finance, disclosure committee, investor relations, risk, technology e

executive leadership. Preserve responsabilidades, expertise, escalonamento e evidência relevante ao Item 106.

Chapter 06 — Integração com enterprise risk management

Integre identificação e tratamento de cyber risk ao ERM para avaliar efeitos materiais e razoavelmente prováveis de forma consistente com outros riscos. Preserve vínculos entre risk records, business impact, strategy, financial reporting e disclosure workpapers.

Chapter 07 — Identificação e priorização de riscos cibernéticos

Mantenha processo repetível para identificar, avaliar, priorizar e gerir ameaças e impactos de negócio. Inclua third parties, incidentes anteriores, mudanças tecnológicas, exposição de dados, interrupção operacional e consequências legais/regulatórias.

Chapter 08 — Governança de materialidade e registros de decisão

Use processo documentado e específico do emissor baseado em padrões federais de securities law e participação apropriada de counsel. Preserve fatos, fatores quantitativos e qualitativos, incerteza, autoridade decisória, timing e fundamento final.

Chapter 09 — Descoberta de incidentes e escalonamento

Estabeleça escalonamento interfuncional conectando rapidamente security operations a legal, disclosure, finance, investor relations, privacy, business e executives quando um incidente puder ser material. Registre descoberta, marcos de investigação, impactos conhecidos e triggers de materiality review.

Chapter 10 — Processo decisório Form 8-K Item 1.05

Para domestic registrants, mantenha processo controlado para decidir se um cybersecurity incident foi determinado material e requer Item 1.05. Não use Item 1.05 apenas porque o incidente é internamente severo; o gatilho é a determinação de materialidade do emissor.

Chapter 11 — Controle do prazo de quatro business days

Após determinar materialidade, acompanhe o prazo geral de quatro business days para Form 8-K desde a data da determinação. Mantenha timestamps, calendário, responsáveis, contingência e evidência de filing tempestivo ou delayed disclosure válido.

Chapter 12 — Limite do delayed disclosure e processo do Attorney General

Trate atraso por substantial risk to national security or public safety como processo específico da regra, não como decisão interna. Preserve análise legal, comunicações governamentais, determinações escritas, extensões, timing e confidencialidade.

Chapter 13 — Governança do conteúdo da divulgação do incidente

Redija Item 1.05 em torno dos aspectos materiais exigidos usando fatos verificados e evitando detalhe técnico sensível desnecessário. Mantenha source support, review comments, aprovações, version history e controles sobre afirmações especulativas.

Chapter 14 — Controles de amendment e corrective disclosure

Monitore fatos após o filing inicial e mantenha processo para amendments ou corrective disclosure quando aplicável. Preserve motivo, novos fatos, análise jurídica, aprovações, versão protocolada e ligação com a divulgação original.

Chapter 15 — Divulgação anual Regulation S-K Item 106

Mantenha workpapers anuais que sustentem a descrição de cyber risk-management processes, efeitos materiais ou razoavelmente prováveis, board oversight e management roles. Reconcilie narrativa com evidência real de governance, risk, incidents e assurance.

Chapter 16 — Divulgação do processo de risk management

Documente como o emissor avalia, identifica e gere riscos materiais de ameaças cibernéticas, integração com overall risk management, uso material de terceiros e oversight de riscos de third-party service providers.

Chapter 17 — Divulgação de board oversight

Sustente divulgação anual com registros mostrando como o board ou committee recebe informações e exerce supervisão. Evite boilerplate sem suporte em minutes, materials, cadence ou prática real.

Chapter 18 — Divulgação de expertise e papel de management

Mantenha evidência sobre posições ou committees responsáveis, expertise relevante quando divulgada e processos pelos quais management recebe informação e reporta ao board.

Chapter 19 — Limite Form 6-K para foreign private issuers

Mantenha análise separada de obrigações de Form 6-K e sua relação com divulgação/publicização em jurisdição estrangeira, stock exchange ou security holders. Não aplique automaticamente a mecânica doméstica de Form 8-K.

Chapter 20 — Limite Form 20-F para foreign private issuers

Mantenha workpapers anuais de Form 20-F para risk management, strategy e governance aplicáveis a FPIs. Reconcilie terminologia e timing ao formulário vigente.

Chapter 21 — Controles de Inline XBRL tagging

Aplique requisitos vigentes de Inline XBRL. Mantenha taxonomy/version control, revisão de tagging, validation evidence, filing previews, correções e coordenação com filing vendors/systems.

Chapter 22 — Disclosure controls and procedures

Incorpore cybersecurity disclosure aos disclosure controls. Defina captura de informação, escalonamento, materiality review, drafting, approval, filing, evidence retention, testing, deficiency management e reassessment periódico.

Chapter 23 — Coordenação legal, investor relations, security e executives

Mantenha protocolo interfuncional que preserve security facts, legal judgment, market communications, financial implications e executive accountability. Defina decision rights e disponibilidade de emergência antes do incidente.

Chapter 24 — Preservação de evidência e disclosure workpapers

Preserve fatos do incidente, source records, materiality analyses, drafts, approvals, filing timestamps, evidência de board/management, suporte anual e control testing em estrutura rastreável com acesso e retenção adequados.

Chapter 25 — Considerações de incidentes e dependências de terceiros

Inclua third-party systems, cloud providers, processors, vendors e dependências materiais. Registre ownership, notification, business impact, data exposure, contractual rights, limitações de investigação e materiality específica do emissor.

Chapter 26 — Considerações de cyber insurance e risk transfer

Trate insurance, indemnity e risk transfer como contexto de gestão, não substitutos de incident response ou disclosure. Preserve coverage facts, limitations, recoveries/exposures materiais e coordenação com disclosure/financial reporting.

Chapter 27 — Interface com enforcement, litigation e investigation

Acompanhe developments de enforcement, litigation, investigations e interpretive material como evidência datada. Não converta allegations, settlements ou rulings específicos em requisitos universais sem análise jurídica.

Chapter 28 — Controles de confidentiality, privilege e need-to-know

Coordene com counsel a preservação de privilege, work product, market-sensitive information e security-sensitive technical facts. Confidencialidade não deve obstruir divulgação ou retenção exigida.

Chapter 29 — Métricas, reporting e continuous improvement

Defina métricas para incident escalation timing, materiality-review cycle time, disclosure readiness, control testing, disponibilidade de informações de terceiros, qualidade da evidência anual, filing defects e remediation. Use tendências para melhorar governança, não como prova isolada de compliance.

Chapter 30 — Revisão independente e disclosure assurance

Use revisão legal, internal audit, compliance ou control assurance independente conforme apropriado. Preserve scope, independence, samples, findings, limitations, remediation e closure; não descreva revisão interna como aprovação da SEC.

Chapter 31 — Arquitetura de evidência, rastreabilidade e retenção

Mantenha rastreabilidade desde rule/form requirement até policy, procedure, owner, system, incident, materiality decision, disclosure workpaper, filing, control test, finding, remediation e source version. Aplique retenção e acesso conforme securities law e demais requisitos aplicáveis.

Chapter 32 — Reverificação de fontes e roadmap de implementação

Antes de cada release, verifique Release 33-11216, Forms 8-K/6-K/10-K/20-F, Regulation S-K Item 106, Inline XBRL, guidance SEC vigente e amendments efetivos. Registre mudanças, impacto, controles atualizados, training, workpapers e ações via change governance.

Conjunto mínimo de evidências de implementação

Mantenha, conforme aplicável: issuer/applicability assessment; registro de fontes SEC; governance e management accountability; cyber-risk register; materiality methodology e decisions; incident escalation; Item 1.05 decision/timing; delayed-disclosure records; drafts/approvals; Item 106 workpapers; FPI analysis; Inline XBRL validation; disclosure-control testing; coordenação legal/IR/security; third-party incident analysis; assurance findings; remediation e release-time source verification.